Gobierno de la Ciberseguridad y Análisis de Riesgos

# Tema 2. Gobierno de la seguridad de la información

# Índice

Esquema

Ideas clave

2.1. Introducción y objetivos

2.2. Gobierno de la seguridad de la información

2.3. Buenas prácticas de seguridad en la gestión de servicios de TI

2.4. Referencias bibliográficas

A fondo

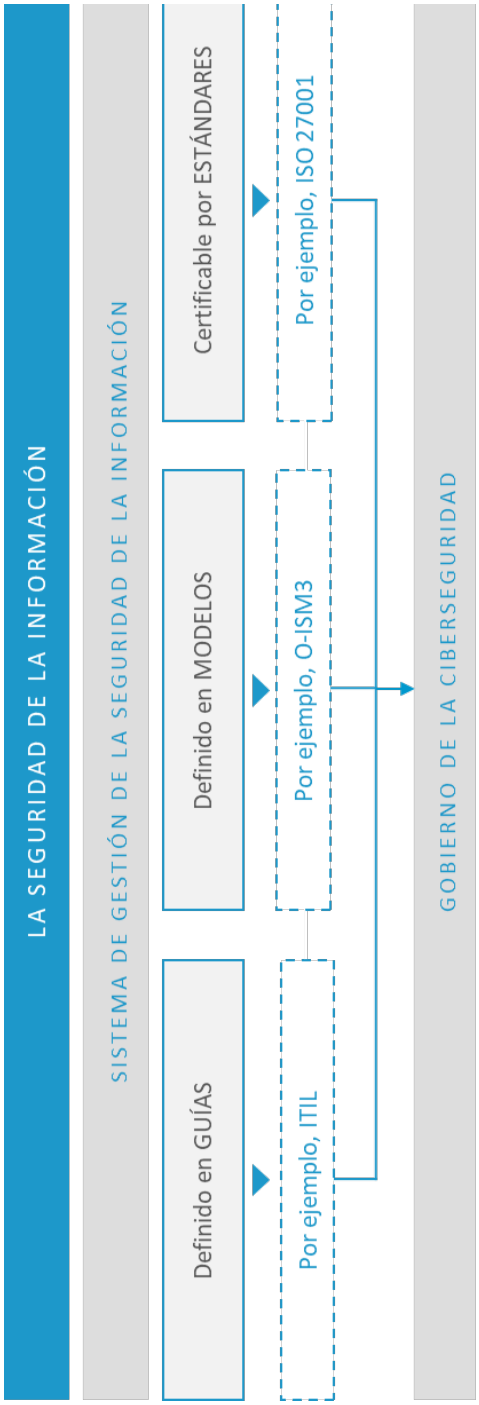
Plan director de seguridad

The ITIL Wiki

Webinar: ITIL and the ITIL Process Map

Test

# Esquema






© Universidad Internacional de La Rioja (UNIR)

## 2.1. Introducción y objetivos

El objetivo fundamental de este tema es el de conocer en qué consiste el **gobierno corporativo de la seguridad de la información,** así como los principales estándares. Este conocimiento es esencial para comprender los conceptos que son necesarios para gestionar adecuadamente la protección de la información.

Más concretamente, los objetivos de este tema son los siguientes:

- Adquirir los conocimientos fundamentales acerca del gobierno de la seguridad de la información.
- Conocer modelos de buenas prácticas de gestión en el área de la Seguridad de la Información y saber diferenciarlos entre sí y con relación a los estándares de certificación.

Este tema trata de introducirte en los términos y conceptos más relevantes en la gestión de la seguridad de la información, introduciendo conceptos enfocados a la estrategia de la seguridad y cómo esta debe estar alineada con los objetivos corporativos.

Es especialmente importante, por su relevancia como organización, dedicar tiempo a entender y conocer en detalle la librería *ITIL* en lo relativo a su marco conceptual y terminología.


© Universidad Internacional de La Rioja (UNIR)

## 2.2. Gobierno de la seguridad de la información

E l **gobierno es** el conjunto de responsabilidades y prácticas ejercidas por la Dirección con la finalidad de brindar una **dirección estratégica,** garantizar que se logren los **objetivos,** determinar que los **riesgos** se administren en forma apropiada y verificar que los **recursos** de la empresa se utilicen con responsabilidad.

### De forma más pormenorizada y focalizándolo en la seguridad de la información, el gobierno de la seguridad trata de:

**Dar una dirección estratégica y apoyar la consecución de objetivos**

- Se debe **alinear la seguridad de la información con la estrategia de negocio** para apoyar los objetivos de la organización.
- Asimismo, se **optimizarán las inversiones** en la seguridad en apoyo a los objetivos del negocio.

**Gestionar adecuadamente los riesgos**

- **Identificar y valorar los riesgos** que se ciernen sobre la organización.
- Se deben **implantar medidas adecuadas** para mitigar los riesgos y reducir el impacto potencial que tendrían en los recursos de información a un nivel aceptable.

**Verificar que los recursos se utilicen con responsabilidad**

- Se buscará **utilizar el conocimiento y la infraestructura disponible** de la mejor forma posible.
- Se deberá controlar y monitorizar la **eficacia y la eficiencia de los controles** ya implantados.



© Universidad Internacional de La Rioja (UNIR)

## Visión, misión y objetivos en el gobierno de la seguridad

Al igual que el gobierno corporativo define una visión, una misión y unos objetivos que dotan a la organización de sus fundamentos estratégicos, el gobierno de la seguridad de la información debe definir una estrategia para cooperar en las metas definidas.

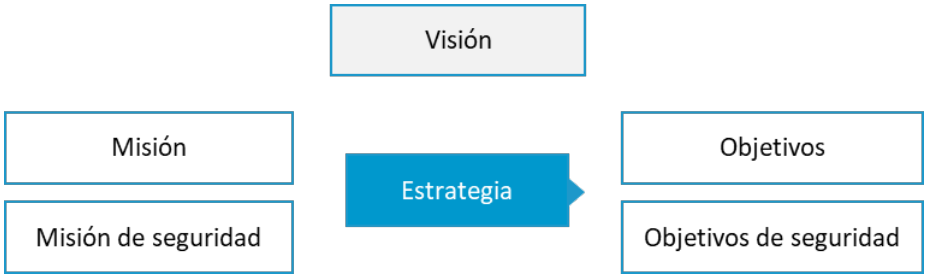



Figura 1. Visión, misión, objetivos y estrategia en el gobierno de la seguridad. Fuente: elaboración propia.

**Misión de la seguridad**

Descripción de **por qué la seguridad de la información es relevante en la organización.** Describe una realidad prácticamente invariable en el tiempo y que puede lograrse de diversas formas, sirviendo de contexto para la toma de decisiones en la entidad.

**Visión de la seguridad**

Describe lo que la entidad **desea que llegue a ser la seguridad de la información,** revisándose de forma periódica y sirviendo de guía para la definición de la estrategia de seguridad.

**Estrategia de seguridad**

La estrategia de seguridad **se revisa periódicamente** debido a los permanentes cambios en el entorno y describe **cómo alcanzar las metas definidas.**



© Universidad Internacional de La Rioja (UNIR)

Concretamente contiene:

- De qué forma la seguridad **da valor** a la entidad, ligando sus iniciativas a las de negocio.
- Cómo **reducir los riesgos,** teniendo en cuenta el cumplimiento normativo y la reducción de costos.
- Cómo se **protege la organización** contra impactos de negocio, cómo esta responde a la evolución de las amenazas y de qué forma se pretende mejorar las medidas ya existentes: formación, tecnología, concienciación, etc.

## Plan Director de Seguridad

El Plan Director de Seguridad es una herramienta fundamental a la hora de implantar la estrategia de seguridad en una organización en un periodo de tiempo que abarca normalmente de 2 a 5 años como máximo.

Es un elemento básico que permite a una organización:

- Definir y establecer las directrices de seguridad de la información que debe adoptar la organización en consonancia con los objetivos corporativos.
- Definir, planificar y formalizar las actividades en seguridad de la Información.

De forma simplificada, un Plan Director de Seguridad trata de determinar:

- El **estado actual** de la seguridad de la información en la organización y de la gestión de los riesgos.
- El **resultado deseado** que se pretende alcanzar dentro de un periodo de tiempo fijado en función de los objetivos de seguridad que deben ser coherentes, medibles y alcanzables.
- El **plan de proyectos** que describa como se van a alcanzar dichos objetivos.


© Universidad Internacional de La Rioja (UNIR)

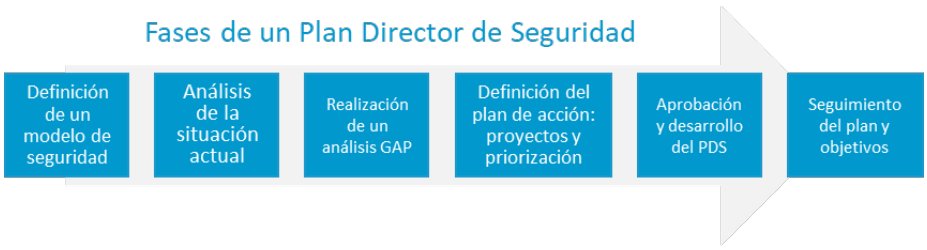



Figura 2. Fases de un Plan Director de Seguridad. Fuente: elaboración propia.

El modelo de seguridad deberá tener en cuenta:

- Los **objetivos y la estrategia corporativa:** Resultado deseado que se pretende alcanzar dentro de un periodo de tiempo fijado
- La gestión de los **riesgos:** Conocer los riesgos y cómo gestionarlos.
- Las **necesidades del negocio:** Primero fijar los objetivos de seguridad y luego las medidas o controles de seguridad que se desarrollan como parte del modelo.
- Los estándares y **buenas prácticas** del sector.
- Las **circunstancias** tecnológicas y operativas.

Para lograr cumplir los objetivos marcados, el plan de proyectos debe tener en cuenta el conocimiento interno de la empresa, los recursos, el presupuesto y la tecnología disponible.


© Universidad Internacional de La Rioja (UNIR)

## 2.3. Buenas prácticas de seguridad en la gestión de servicios de TI

La gestión de los **servicios de Tecnología de la Información** (TI) ha evolucionado desde una organización *ad hoc* centrada en la visión técnica de los recursos de TI a una **visión integradora** que considera los **aspectos humanos, sociales y tecnológicos** que intervienen en un servicio de TI.

> Es un servicio a uno o más clientes, por un proveedor de servicios de TI. Un servicio de TI se basa en el uso de tecnologías de la información y apoya al cliente en sus procesos de negocio. Un servicio de TI se compone de una combinación de personas, procesos y tecnología y debe definirse en un acuerdo de nivel de servicio.

La definición indica varios elementos fundamentales en la gestión de los servicios:

- En primer lugar, hace referencia al **apoyo al cliente en sus tareas.** Esta es una consideración central y es especialmente importante, dado que un fallo en un servicio de TI en muchas ocasiones implica que hay usuarios que no pueden hacer su trabajo.

- En segundo lugar, un servicio tiene tres componentes: **personas, procesos y tecnología** y estos tres elementos deben tenerse en cuenta en la definición, diseño y evaluación de cada servicio.

- Por último, la definición hace referencia a los **Acuerdos de Nivel de Servicio** *(Service Level Agreement, SLA),* que pueden entenderse como los contratos entre los usuarios y proveedores del servicio, dando un carácter de predictibilidad a los servicios y permitiendo una evaluación del servicio no ambigua, dado que los niveles de calidad son explícitos en los acuerdos. Más adelante veremos algunos detalles


© Universidad Internacional de La Rioja (UNIR)

sobre la forma de estos acuerdos.

Los acuerdos de nivel de servicio *(service-level agreement, SLA)* son **acuerdos formales** sobre la división de la responsabilidad de los medios de **computación entre el Departamento de Sistemas de Información (DSI) y los usuarios finales.** Estos acuerdos pueden considerarse contratos, y deben abarcar todos los recursos fundamentales de las tecnologías de la información: *hardware, software,* personal, datos, redes y procedimientos.

De hecho, los SLA no son específicos de las relaciones de los DSI, sino que se utilizan para todo tipo de relaciones de provisión de servicios. Se definen de manera general como un protocolo plasmado normalmente en un documento de carácter legal por el que una compañía que presta un servicio a otra se compromete a prestar el mismo trabajo bajo unas determinadas condiciones y con prestaciones mínimas. Se utilizan también con profusión en contratos de *outsourcing.*

La fundamental ventaja de un SLA es que las responsabilidades quedan claramente definidas y los procesos para el funcionamiento diario también están determinados de manera precisa.

SLA: garantía de disponibilidad de red

Se define como tiempo en que el servidor tiene disponible la conectividad a internet en el puerto de red asignado. La disponibilidad del servicio se calcula según la siguiente fórmula:

$$D = (T - Td)/T$$

Donde:

es el tiempo de disponibilidad del servicio.$D$

es el tiempo total mensual.$T$



© Universidad Internacional de La Rioja (UNIR)

es el tiempo con pérdida total de conectividad. Este tipo de pérdida será igual a la que transcurre desde la apertura de la incidencia, hasta el cierre de dicha incidencia. $Td$

En caso de pérdida de disponibilidad real de este nivel de servicio, se aplicarán las penalizaciones de la siguiente tabla de acuerdo con las condiciones de penalización generales del contrato.

| Penalizaciones: | |
|---|---|
| $99\ \% > D \geq 98\ \%$ | Nivel A |
| $98\ \% > D \geq 96\ \%$ | Nivel B |
| $96\% > D \geq 90\ \%$ | Nivel C |
| $D < 90\ \%$ | Nivel D |

Tabla 1. Pérdida de disponibilidad real del servicio con base en las condiciones de penalización generales del contrato.

Cálculo del tiempo de caída: en el cálculo de esta magnitud se establecerá desde que se ha dado noticia al DSI del problema. El tiempo de incidencia finaliza cuando el DSI comprueba que dicho servicio se ha restaurado completamente.

No se considera tiempo de caída aquel debido a problemas derivados de un mal uso de la red o una mala configuración de la red por parte del cliente.

## Las buenas prácticas en los servicios de TI: *ITIL*



© Universidad Internacional de La Rioja (UNIR)

# Ideas clave

La práctica de la gestión de los servicios de TI maduró progresivamente durante los años ochenta. El gobierno británico, guiado por la necesidad de una **gestión más efectiva** de esos servicios, comenzó a recopilar las formas en las que las organizaciones con más éxito gestionaban sus servicios. Esto llevó a la primera versión de la IT Infrastructure Library (ITIL) al final de los ochenta, que no era otra cosa que un conjunto de libros documentando los hallazgos de los estudios mencionados.

El Information Technology Service Management Forum (itSMF) es el único **grupo de usuarios** internacionalmente reconocido e independiente **dedicado a la gestión de servicios TI**, que surgió como un foro para que los usuarios de ITIL pudiesen intercambiar experiencias y aprender colectivamente. Es propiedad de sus miembros y son ellos quienes lo operan. El itSMF tiene **gran influencia** y contribuye a la industria de las mejores prácticas y a los estándares a nivel mundial.

La **primera filial del itSMF** se fundó en el Reino Unido en 1991. El itSMF holandés (itSMF Holanda) fue la siguiente, establecida en noviembre de 1993. Ahora existen filiales itSMF en países como Sudáfrica, Bélgica, Alemania, Austria, Suiza, Canadá, Estados Unidos, Francia y Australia, que cooperan con itSMF Internacional.

**OGC** (The Office of Government Commerce) es la Oficina independiente del Tesoro en el Reino Unido (RU). El objetivo de la OGC es definir estándares y proporcionar las mejores prácticas para el mercado del RU. La OGC es la dueña de ITIL® y el desarrollo de ITIL® v3 ha sido auspiciado por la OGC.

La **APMG,** o el Grupo APM Group, han sido contratados por la OGC para ser el **proveedor acreditado** en los siguientes años. Él definirá el estándar de los exámenes, la provisión de los exámenes, y entrenadores capacitados, materiales de capacitación y proveedores de capacitación de ITIL® v3.

El principio fundamental de ITIL es el de recoger todas las prácticas que funcionan.


© Universidad Internacional de La Rioja (UNIR)

Esta aproximación se resume en unas características clave que pueden resumirse en las siguientes:

**ITIL no es propietario**

Las prácticas de ITIL no son específicas de ningún tipo de tecnología o de sector. Además, ITIL es propiedad del gobierno británico, no estando por lo tanto en manos de ningún proveedor concreto.

**ITIL no es prescriptivo**

ITIL recoge prácticas maduras, probadas de aplicabilidad general. Por su carácter genérico, no establece ningún tipo de obligatoriedad o uso concreto de tecnologías o técnicas.

**ITIL consiste en las mejores prácticas**

ITIL recoge las mejores prácticas a nivel global, por lo tanto, es el resultado de la experiencia acumulada.

**ITIL consiste en buenas prácticas**

No todas las prácticas en ITIL pueden considerarse como las «mejores». Esto es una consecuencia del carácter evolutivo de la práctica. Lo que hoy es lo mejor, mañana pasará simplemente a ser bueno o común, dado que se habrán descubierto formas mejores de hacer lo mismo o bien el entorno habrá cambiado.

ITIL abarca prácticas de soporte y de entrega del servicio. La siguiente figura las esquematiza.


© Universidad Internacional de La Rioja (UNIR)

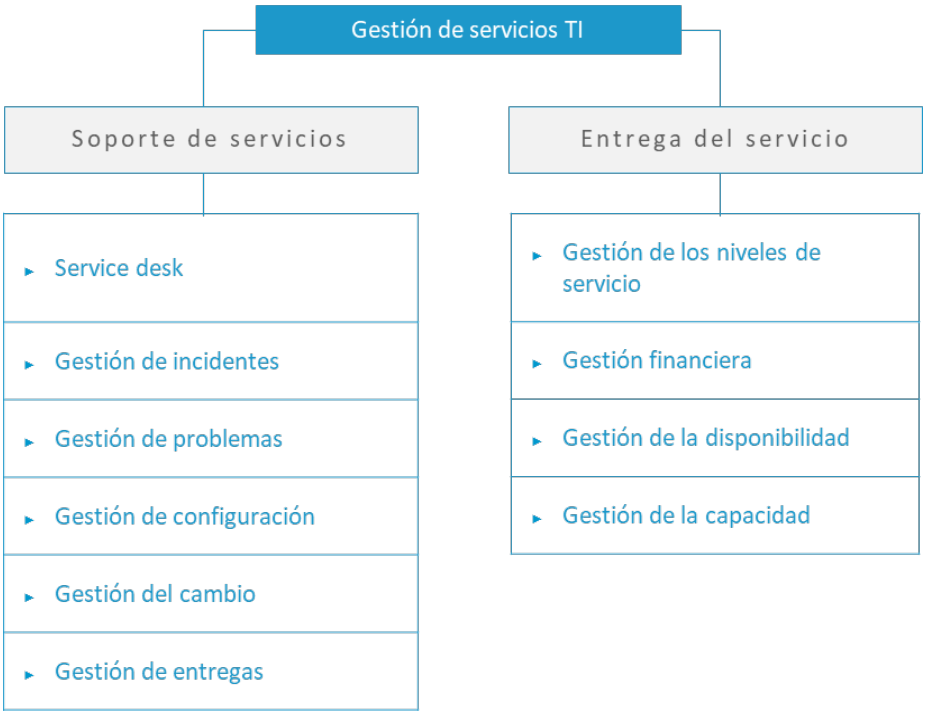



Figura 3. Esquema de gestión de servicios TI. Fuente: elaboración propia.

Las prácticas que ITIL recoge tienen unas **características comunes** cuando se observa su tipo y cómo las aplican las mejores organizaciones de servicio. Esas características pueden resumirse en los siguientes puntos:

- Son predictivos en lugar de reactivos. Es decir, se basan en estudiar los patrones de uso de los clientes o usuarios.
- Son consistentes y medibles. Las mejores prácticas son estables y proporcionan predictibilidad a los servicios de TI.
- Son adaptables. Por último, las prácticas deben permitir su optimización y mejora continua.

Tomemos como ejemplo la práctica de la «Gestión de la capacidad». Podemos definirla cómo la práctica encargada de «asegurar que la infraestructura de TI se proporciona cuando se necesita, en el volumen necesario y con el precio adecuado,


© Universidad Internacional de La Rioja (UNIR)

garantizando su uso eficiente».

Siguiendo el esquema anterior, como toda práctica ITIL, debe ser:

**Predictiva**

Esto se refleja, por ejemplo, en considerar que un factor crítico de éxito en esta práctica es proporcionar previsiones de demanda de TI precisas.

**Consistente**

Esto se refleja, por ejemplo, en la necesidad de implementar políticas, procesos y procedimientos de gestión de la capacidad.

**Medible**

Esto se refleja en los indicadores recomendados para la evaluación del servicio. Para esta práctica, entre los KPI *(key performance indicators)* tenemos, por ejemplo:

- Dólares en capacidad de TI no utilizada.
- Número de incidentes/violaciones de SLA debidos a la capacidad.

**Adaptable**

Entre las actividades encontramos implementar cambios relacionados con la capacidad.

Es importante entender que las recomendaciones y directrices relativas a cada práctica tienen en cuenta las cuatro características que acabamos de comentar.

## El proceso de gestión de la seguridad en ITIL

El proceso de gestión de la seguridad en ITIL se basa en la **norma ISO 27001** que ya hemos visto. Para diseñar los procesos, las entradas son los requisitos que se formulan por parte de los clientes. Estos requisitos se traducen en **servicios de**



© Universidad Internacional de La Rioja (UNIR)

**seguridad y de calidad de seguridad** que debe ser proporcionada en la sección de seguridad de los acuerdos de nivel de servicio. El proceso de gestión de la seguridad en ITIL es complejo y abarca un buen número de diferentes actividades. La siguiente tabla resume algunas de ellas.

| Subproceso | Objetivo |
|---|---|
| Diseño de controles de seguridad | Diseñar las medidas técnicas y organizativas necesarias para asegurar la disponibilidad, integridad y confidencialidad de los recursos y servicios de información. |
| Pruebas de seguridad | Asegurar que los mecanismos de seguridad están sujetos a pruebas regulares. |
| Gestión de incidentes de seguridad | Detectar y combatir los ataques y las intrusiones, y minimizar el daño de las brechas de seguridad |
| Revisión de la seguridad | Revisar si las medidas y procedimientos de seguridad son coherentes con las percepciones de riesgo del negocio, y si esas medidas y procedimientos se revisan y evalúan regularmente |

Tabla 2. Procesos de gestión de la seguridad en ITIL. Fuente: elaboración propia.

Respecto a los indicadores, la siguiente tabla describe indicadores típicos para este proceso.


© Universidad Internacional de La Rioja (UNIR)

| KPI | Descripción |
|---|---|
| Número de medidas de prevención implementadas | Número de medidas de prevención implementadas en respuesta a amenazas a la seguridad identificadas |
| Duración de la implementación | Tiempo transcurrido desde la identificación de una amenaza hasta la implementación de una contramedida adecuada |
| Número de incidentes de seguridad importantes | Número de incidentes, clasificados por severidad |
| Número de caídas del nivel de servicio relacionadas con la seguridad | Número de incidentes que han causado no disponibilidad del servicio de limitada o interrupción |
| Número de test de seguridad | Número de *test* de seguridad (y de procesos de formación) llevados a cabo |
| Número de problemas identificados durante los test | Número de problemas identificados en el transcurso de los *test* de seguridad |

Tabla 3. Indicadores típicos para los procesos de gestión de la seguridad en ITIL. Fuente: elaboración propia.

Es interesante detenerse a pensar cómo los KPI que se acaban de mencionar se relacionan con los modelos económicos de la seguridad. Las medidas de prevención son pre-incidente, así como los test, si bien el número de incidentes es post-incidente. La orientación al servicio hace que uno de los KPI tenga que ver con el concepto de disponibilidad de manera directa.


© Universidad Internacional de La Rioja (UNIR)

## 2.4. Referencias bibliográficas

Página de ISACA.


© Universidad Internacional de La Rioja (UNIR)

## Plan director de seguridad

Ministerio de Asuntos Económicos y Transformación digital, Gobierno de España. *Plan Director de Seguridad.* Incibe. https://www.incibe.es/sites/default/files/contenidos/dosieres/metad_plan-director-seguridad.pdf

Guía de buenas prácticas confeccionada por INCIBE (Instituto Nacional de Ciberseguridad) para la elaboración del Plan Director de Seguridad para cualquier tipo de organización.


© Universidad Internacional de La Rioja (UNIR)

## The ITIL Wiki

Página de IT Process Wiki: The ITIL Wiki.

Completa web informativa con toda la información necesaria para entender el funcionamiento de ITIL, procesos, KPIs y certificaciones disponibles.


© Universidad Internacional de La Rioja (UNIR)

## Webinar: ITIL and the ITIL Process Map

ITIL Process Map. (5 de octubre de 2015*). Webinar: ITIL and the ITIL Process Map* [Vídeo]. YouTube. https://www.youtube.com/watch?v=j8n1bRbsdwQ

Seminario web donde el experto Stefan Kempter desarrolla el Mapa de procesos de ITIL v4, presentando un conjunto completo de plantillas de procesos y documentos para organizaciones o proveedores de servicios que desean alinear sus operaciones con el servicio de TI.


© Universidad Internacional de La Rioja (UNIR)

**1.** Indica cuál de las siguientes opciones no es un objetivo del gobierno de la seguridad:

A. Alinear los objetivos de seguridad con los objetivos estratégicos.

B. Lograr siempre el mínimo coste en el proceso de seguridad.

C. Gestionar de forma adecuada los riesgos de la seguridad de la información.

D. Manejar de la mejor forma posible los recursos disponibles para alcanzar los objetivos fijados.

**2.** Indica qué fase de las siguientes opciones nunca formará parte de un Plan Director de Seguridad:

A. Diagnóstico del estado de la seguridad de la información actualmente en una entidad.

B. Cumplir todos y cada uno de los controles definidos en el estándar ISO/IEC 27001.

C. Identificación de la diferencia de madurez en seguridad de la información de la entidad en la actualidad respecto al estado deseado.

D. Revisión de los objetivos y la estrategia corporativa.

**3.** Indica qué roles están involucrados en la seguridad de la información de una empresa:

A. El encargado de la limpieza en las oficinas.

B. El responsable del cumplimiento normativo de la entidad.

C. El CEO de la empresa.

D. Todos estos roles tienen implicación en la seguridad de la información de una empresa.



© Universidad Internacional de La Rioja (UNIR)

**4.** Indica cuál de las siguientes opciones no es cierta dentro de una estrategia de seguridad:

A. La estrategia de seguridad debe revisarse periódicamente.

B. Debe ser independiente de la estrategia de negocio de la organización para mantener la visión de los objetivos TIC.

C. Debe tener en cuenta los valores de riesgo para buscar la reducción de estos.

D. Debe tener en cuenta todos los aspectos de mejora de las medidas de seguridad existentes en la organización.

**5.** Indica cuál de los siguientes aspectos debe tenerse en cuenta a la hora de definir un Plan Director de Seguridad:

A. Los dominios de seguridad definidos por la ISO 27001.

B. El organigrama de la compañía.

C. Los niveles de riesgo y de control actualizados.

D. El documento SOA definido, indicando la aplicabilidad de los controles de seguridad en la compañía.

**6.** Indica cuál de los siguientes aspectos no debe tenerse en cuenta en la fase de definición del plan de acción del Plan Director de Seguridad:

A. Definir el alcance de cada uno de los proyectos de seguridad que formarán parte del plan de acción.

B. Estimación y dedicación de recursos humanos y económicos al Plan de acción.

C. Priorizar y planificar los proyectos de seguridad.

D. Implementación de controles para mitigar los riesgos de mayor nivel.



© Universidad Internacional de La Rioja (UNIR)

**7.** Indica cuáles de las siguientes afirmaciones no son ciertas:

A. La definición de SLAs es uno de los elementos básicos en un servicio de TI.

B. Cualquier compañía que provea servicios relacionados con las TI puede obtener una certificación ITIL.

C. Un servicio relacionado con las TI no tiene por qué conllevar la entrega de un producto TIC.

D. Todas las anteriores.

**8.** Indica cuáles de las siguientes afirmaciones son ciertas:

A. Los servicios de TI se definen mediante SLA, que determinan el nivel de calidad de los servicios en diferentes dimensiones.

B. El proceso de gestión de la seguridad de ITIL prescribe los requisitos de un SGSI si quiere ser compatible con ITIL.

C. ITIL solo es compatible con la última versión de la ISO 27001, pero no lo fue con las anteriores.

D. Ninguna de las anteriores.

**9.** Indica cuáles de las siguientes opciones son ventajas de los SLA:

A. Identifican claramente las responsabilidades, en el marco del servicio, del departamento TIC y de los usuarios finales.

B. Tienen en cuenta recursos no sólo TIC, sino de otra naturaleza: personal, datos, procedimientos, etc.

C. Pueden utilizarse en contratos de outsourcing.

D. Todas las anteriores.



© Universidad Internacional de La Rioja (UNIR)

**10.** Indica cuáles de las siguientes opciones son características de las buenas prácticas de ITIL:

A. Son reactivas en lugar de predictivas.

B. Permiten la optimización y mejora continua.

C. Son siempre las mejores prácticas posibles para cada aspecto de la gestión de servicios TIC.

D. Todas las anteriores.


© Universidad Internacional de La Rioja (UNIR)